

Industry-Focused Threat Hunting, APT TTP Mapping & Control Alignment

Sector: **Financial Services**

Prepared for: Security Operations Center (SOC) Leadership
Classification: Internal Use Only
Date: May 2026

Section	Title	Page
Task 1	Industry Threat Landscape	2
Task 2	TTP Analysis Using MITRE ATT&CK;	4
Task 3	ATT&CK; Navigator Mapping & Overlap Analysis	7
Task 4	Detection & Control Mapping (NIST & ISO)	9

TASK 1: Industry Threat Landscape

1.1 Selected Industry: Financial Services

The financial services sector, encompassing retail banks, investment banks, insurance carriers, payment processors, and capital markets infrastructure, represents one of the highest-value targets in the global threat landscape. Several converging factors make this industry uniquely attractive to nation-state actors, cybercriminal organizations, and hackers alike.

Why Financial Services Is a High-Value Target

- **Monetary gain:** Direct access to funds, SWIFT interbank transfers, and cryptocurrency wallets enables immediate financial theft. The 2016 Bangladesh Bank heist via SWIFT netted attackers approximately \$81 million USD.
- **Economic espionage:** Merger & acquisition data, trading algorithms, sovereign bond holdings, and sanctions intelligence hold significant geopolitical value for nation-state actors.
- **Systemic disruption:** Attacks on clearing houses, payment rails, or central banks can cascade into broader economic instability, a strategic objective for state-sponsored threat actors.

- **Regulatory data richness:** KYC/AML databases, credit files, and tax records provide intelligence services with deep population-level profiling capabilities.
- **Extensive attack surface:** Legacy mainframes, third-party fintech integrations, open banking APIs, and widespread remote-access infrastructure collectively expand exploitable entry points.
- **High ransom leverage:** Operational downtime is extraordinarily costly; financial institutions are statistically more likely to pay ransoms quickly to restore operations.

According to the IBM X-Force Threat Intelligence Index and Verizon DBIR, financial services consistently ranks in the top three most-targeted industries globally, making it an ideal sector for advanced, evidence-based threat hunting.

1.2 Selected APT Groups

Five APT groups with documented, significant activity targeting the financial services sector were selected. Each represents a distinct threat archetype, from nation-state espionage to financially motivated cybercrime.

APT Group	Origin	Motivation	Typical Targets	Notable Campaigns
APT38 (Lazarus sub-group)	North Korea (DPRK)	Financial theft (fund DPRK regime)	Central banks, SWIFT operators, crypto exchanges	Bangladesh Bank (2016); FAR heist; crypto exchange attacks
FIN7 (Carbanak group)	Russia / Eastern Europe	Financial gain (criminal)	Retail banks, POS networks, hospitality financial systems	Carbanak campaign; FIN7 restaurant/retail campaigns
APT29 (Cozy Bear)	Russia (SVR)	Espionage / intelligence gathering	Investment banks, treasury departments, M&A advisors	SolarWinds supply chain; US Treasury breach (2020)
APT41 (Double Dragon)	China (MSS affiliated)	Dual: espionage + financial crime	FinTech, insurance, capital markets, gaming/crypto	Operation CuckooBees; Payroll fraud campaigns
APT Group	Origin	Motivation	Typical Targets	Notable Campaigns
Silence Group	Russia / Eastern Europe	Financial theft (criminal)	Banks, ATM networks, card processing systems	ATM jackpotting; Trflphone / Silence malware campaigns

Table 1: Selected APT Groups Targeting Financial Services

1.3 APT Group Profiles

APT38 (Lazarus Sub-Group DPRK)

Primary Motivation: Espionage / Financial Theft

APT38 is a financially motivated threat actor operating under the direction of the North Korean Reconnaissance General Bureau. Unlike typical espionage groups, APT38 directly steals funds to support DPRK weapons programs under international sanctions. The group is uniquely patient, often spending months inside victim

networks before executing multi-million-dollar SWIFT transfer frauds. Key tools include HOPLIGHT, ELECTRICFISH, and BLINDINGCAN malware. APT38 is responsible for over \$1.3 billion USD in attempted thefts (US DOJ).

FIN7 / Carbanak (Criminal Syndicate)

Primary Motivation: Financial Gain

FIN7 pioneered APT-level tradecraft for financial crime, employing targeted spear phishing, malicious macro-laced Office documents, and custom backdoors (CARBANAK, BABYMETAL, GRIFFON). Once inside, operators conduct extensive reconnaissance to locate payment processing systems, ATM controllers, and money-mule infrastructure. FIN7 has stolen over \$1 billion globally across hundreds of financial institutions.

APT29 / Cozy Bear (SVR Russia)

Primary Motivation: Espionage / Intelligence

APT29, attributed to Russia's SVR, targets financial institutions for economic and geopolitical intelligence rather than direct theft. The group uses legitimate cloud services (Dropbox, OneDrive) as C2 infrastructure, Golden SAML attacks, and extensive living-off-the-land tactics. Their 2020 SolarWinds campaign compromised the US Treasury and Commerce departments.

APT41 / Double Dragon (China MSS-affiliated)

Primary Motivation: Dual: Espionage + Financial Crime

APT41 uniquely conducts both state-sponsored espionage and financially motivated cybercrime. Targeting includes capital markets data, insurance underwriting systems, fintech platforms, and cryptocurrency exchanges. Operation Cuckoo Bees revealed APT41's multi-year persistence inside financial firms. The group exploits web-facing vulnerabilities (Citrix, Pulse Secure) and uses DEADEYE, LOWKEY, and MESSAGETAP malware.

Silence Group (Criminal — Russia/Eastern Europe)

Primary Motivation: Financial Theft

Silence Group specializes in banks and financial infrastructure — ATM jackpotting, fraudulent interbank transfers, and card processing compromise. Operators repurpose legitimate pen test tooling (Impacket, Metasploit, Bloodhound) for post-compromise activity. Campaigns have been documented across Eastern Europe, Asia, and Latin America.

TASK 2: TTP Analysis Using MITRE ATT&CK;

The following section maps documented TTPs for each APT group across the MITRE ATT&CK; Enterprise matrix lifecycle. Focus is placed on post-compromise behaviors including credential access, lateral movement, and command and control (★ = highlighted technique).

2.1 ATT&CK; TTP Mapping Table

APT Group	Tactic	Tech. ID	Technique Name	Relevance
APT38	Initial Access	T1566.001	Spear phishing Attachment	Initial entry via finance staff email

APT38	Execution	T1059.001	PowerShell	Payload execution & staging
APT38	Persistence	T1547.001	Registry Run Keys	Maintain foothold across reboots
APT38	Credential Access ★	T1003.001	LSASS Memory Dumping	Harvest domain credentials
APT38	Lateral Movement ★	T1021.002	SMB/Windows Admin Shares	Pivot to SWIFT terminals
APT38	C2 ★	T1071.001	Web Protocols (HTTP/S)	ELECTRICFISH tunnel
APT38	Exfiltration	T1048	Exfil Over Alt Protocol	Data staging before wire transfer
APT38	Impact	T1485	Data Destruction	Wipe evidence post-heist
FIN7	Initial Access	T1566.002	Spear phishing Link	Lure to credential harvesting
FIN7	Execution	T1204.002	Malicious File (macro)	BABYMETAL/GRIFFON dropper
FIN7	Persistence	T1053.005	Scheduled Task	Maintain persistence on POS systems
FIN7	Credential Access ★	T1056.001	Keylogging	Capture banking credentials
FIN7	Lateral Movement ★	T1021.001	Remote Desktop Protocol	Move to card processing servers
FIN7	C2 ★	T1071.001	Web Protocols (HTTP/S)	CARBANAK C2 over HTTPS
FIN7	Collection	T1560.001	Archive via Utility	Compress card data pre-exfil
FIN7	Exfiltration	T1041	Exfil Over C2 Channel	Card data returned via C2
APT29	Initial Access	T1195.002	Compromise Software Supply Chain	SolarWinds / 3CX attacks
APT29	Execution	T1059.003	Windows Command Shell	Post-compromise enumeration
APT Group	Tactic	Tech. ID	Technique Name	Relevance

APT29	Persistence	T1078	Valid Accounts	Stolen O365 / cloud credentials
APT29	Credential Access ★	T1552.001	Credentials in Files	Config files, git repos
APT29	Lateral Movement ★	T1550.001	Pass-the-Hash / Golden SAML	Cloud identity impersonation
APT29	C2 ★	T1102	Web Service (cloud storage)	OneDrive/Dropbox as C2
APT29	Defense Evasion	T1070.004	File Deletion	Remove indicators of compromise
APT29	Exfiltration	T1567.002	Exfil to Cloud Storage	Data to attacker-controlled cloud
APT41	Initial Access	T1190	Exploit Public-Facing App	Citrix / Pulse Secure exploits
APT41	Execution	T1059.001	PowerShell	Post-exploit staging
APT41	Persistence	T1543.003	Windows Service	LOWKEY rootkit as service
APT41	Credential Access ★	T1003.001	LSASS Memory Dumping	Domain credential harvest
APT41	Lateral Movement ★	T1021.006	Windows Remote Mgmt (WinRM)	Move across financial systems
APT41	C2 ★	T1071.001	Web Protocols (HTTP/S)	DEADEYE implant comms
APT41	Collection	T1114.002	Remote Email Collection	M&A / trading intelligence
APT41	Exfiltration	T1041	Exfil Over C2 Channel	Staged data via implant
Silence	Initial Access	T1566.001	Spearphishing Attachment	Targets bank ops staff
Silence	Execution	T1204.002	Malicious File (macro)	Silence framework dropper
Silence	Persistence	T1547.001	Registry Run Keys	ATM-side persistence
Silence	Credential Access ★	T1003.002	Security Account Manager	Local account harvesting
Silence	Lateral Movement ★	T1021.002	SMB/Windows Admin Shares	Pivot to ATM controllers
Silence	C2 ★	T1095	Non-App Layer Protocol	Custom TCP C2 protocol

Silence	Impact	T1491.001	Defacement / ATM Jackpot	Dispense cash, erase tracks
---------	--------	-----------	--------------------------	-----------------------------

Table 2: APT → Tactic → Technique ID → Technique Name (★ = post-compromise focus)

2.2 Key Technique Highlights

Credential Access

- T1003.001 (LSASS Dumping): Used by APT38 and APT41; provides domain-level credential material enabling broad lateral movement across financial network segments.
- T1056.001 (Keylogging): Core FIN7 technique to silently capture banking credentials from operators of POS and treasury systems.
- T1552.001 (Credentials in Files): APT29's preference for harvesting credentials from config files, scripts, and source repositories reflects its software supply-chain access patterns.

Lateral Movement

- T1021.002 (SMB/Admin Shares): Shared by APT38 and Silence Group; critical for reaching SWIFT terminals and ATM controller networks.
- T1550.001 (Pass-the-Hash / Golden SAML): APT29's signature technique allowing persistent cloud-identity impersonation long after initial credential theft.
- T1021.001 (RDP): FIN7's primary lateral movement method, leveraging legitimate remote desktop to blend with administrator activity.

Command and Control

- T1071.001 (Web Protocols): Dominant C2 channel across APT38, FIN7, and APT41; HTTPS-based C2 blends with legitimate web traffic and evades most network-layer controls.
- T1102 (Web Service): APT29's use of cloud services (OneDrive, Dropbox) as C2 proxies is difficult to detect without CASB and DLP controls.
- T1095 (Non-Application Layer Protocol): Silence Group's custom TCP-based protocol avoids HTTP-based proxy inspection, requiring deep-packet inspection to detect.

TASK 3: ATT&CK; Navigator Mapping & Overlap Analysis

3.1 Individual Navigator Layers

A dedicated ATT&CK; Navigator layer was created for each APT group. The table below summarizes technique counts and color coding applied per layer for import into the MITRE ATT&CK; Navigator (<https://mitre-attack.github.io/attack-navigator/>).

APT Group	Layer Colour	Techniques	Primary Tactic Focus
APT38	Yellow	8	Impact, Credential Access, Exfiltration
FIN7	Purple	8	Initial Access, Credential Access, C2
APT29	Green	8	Persistence, C2, Defense Evasion
APT41	Blue	8	Initial Access, Collection, Persistence
Silence	Orange	7	Lateral Movement, Impact, C2
Combined (Overlap)	Red	8	Techniques used by ≥ 2 APTs

Table 3: ATT&CK; Navigator Layer Summary

Navigator Layer Export: JSON layer files can be imported directly into ATT&CK; Navigator. Each technique is scored 1–3 based on frequency of documented use, with color intensity indicating priority. The overlap (combined) layer uses a heat-map gradient where darker red indicates techniques used by three or more groups simultaneously.

3.2 Overlap Analysis: Techniques Shared by ≥ 2 APTs

Technique ID	Technique Name	APT Groups Using It	Frequency
T1566.001	Spear phishing Attachment	APT38, Silence	2 / 5 APTs
T1059.001	PowerShell Execution	APT38, APT41	2 / 5 APTs
T1547.001	Registry Run Keys	APT38, Silence	2 / 5 APTs
T1003.001	LSASS Memory Dumping	APT38, APT41	2 / 5 APTs
T1021.002	SMB / Windows Admin Shares	APT38, Silence	2 / 5 APTs
		APT38, FIN7, APT41	3 / 5 APTs ★
T1204.002	Malicious File (macro execution)	FIN7, Silence	2 / 5 APTs
T1041	Exfiltration Over C2 Channel	FIN7, APT41	2 / 5 APTs

Table 4: Overlap Techniques (shared by ≥ 2 APTs). ★ = highest-frequency choke point.

3.3 Overlap Significance Analysis (~300 words)

The overlap analysis reveals critical structural patterns in how diverse threat actors targeting financial services converge on a common set of enabling techniques, regardless of their ultimate objectives.

High-Frequency Techniques

The single most significant finding is the dominance of **T1071.001, Web Protocols** as a command and control mechanism, used by three of the five APT groups (APT38, FIN7, APT41). This convergence reflects a rational attacker calculus: HTTPS-based C2 blends seamlessly with legitimate web traffic in financial environments that rely heavily on web-based banking portals, APIs, and SaaS platforms. Traditional network monitoring tools struggle to differentiate malicious HTTPS beacons from normal business traffic without SSL inspection capabilities.

Similarly, **T1003.001, LSASS Memory Dumping** appears across two distinct threat archetypes (nation-state APT38 and dual-purpose APT41), confirming that credential harvesting via the Windows LSASS process is an indispensable post-compromise step regardless of the attacker's ultimate goal.

Choke Point Techniques

From a defensive perspective, the overlap layer identifies the following as 'choke points' where detection investment yields the highest cross-APT defensive value:

- **T1071.001, Web Protocol C2:** Highest leverage: disrupting this single technique degrades capability for 3/5 APTs. Controls: SSL/TLS inspection, DNS filtering, JA3/JA3S fingerprinting, beaconing detection.
- **T1003.001, LSASS Memory Dumping:** Blocking credential-dumping tools provides a cross-APT win against espionage and financial actors. Controls: Credential Guard, PPL protection for LSASS, EDR memory protection rules.
- **T1566.001 / T1204.002, Spear phishing + Malicious Macros:** Shared initial access vectors for APT38, FIN7, and Silence. Controls: email gateway sandboxing, Office macro block policies, DMARC/DKIM enforcement.
- **T1021.002, SMB Admin Share Traversal:** Shared lateral movement path for SWIFT-targeting APT38 and ATM-targeting Silence. Controls: SMB signing enforcement, micro-segmentation of payment networks.

In aggregate, a financial-services SOC that invests in five to seven high-priority detection use cases centered on these choke-point techniques can meaningfully degrade the operational effectiveness of all five analyzed APT groups simultaneously, delivering exceptional return on defensive investment.

TASK 4: Detection & Control Mapping (NIST CSF & ISO/IEC 27001)

Threat intelligence and overlap findings are translated into actionable governance and operational controls, mapped against both NIST CSF 2.0 and ISO/IEC 27001:2022 to support the financial-services SOC.

4.1 NIST CSF 2.0 Mapping

Each NIST CSF 2.0 function is mapped to a specific control action derived from the TTP overlap analysis. Critical controls (those addressing choke-point techniques) are highlighted in red.

NIST CSF Function	Category / ID	Control Action	TTP Addressed	Priority
-------------------	---------------	----------------	---------------	----------

GOVERN (GV)	GV.OC-01 Org Context	Formally classify financial-sector threat actor profiles (APT38, FIN7, APT29, APT41, Silence) within the organization's threat intelligence programmed.	All TTPs	High
IDENTIFY (ID)	ID.AM-02 Asset Inventory	Maintain real-time inventory of SWIFT terminals, ATM controllers, payment processing servers, and identity management systems.	T1021.002 T1491	High
IDENTIFY (ID)	ID.RA-01 Risk Assessment	Conduct annual sector-specific threat assessment using MITRE ATT&CK; overlap data to priorities controls.	All TTPs	High
PROTECT (PR)	PR.AA-02 Identity Mgmt.	Enforce phishing-resistant MFA (FIDO2) for all privileged accounts. Implement PAM. Apply Credential Guard and PPL protection for LSASS.	T1003.001 T1078 T1550.001	Critical
PROTECT (PR)	PR.DS-01 Data Security	Encrypt sensitive financial data at rest and in transit. Apply DLP rules for bulk data staging and archive creation.	T1560.001 T1041 T1048	High
PROTECT (PR)	PR.PS-04 Platform Security	Enforce Group Policy to disable Office macros from internet-sourced files. Apply application allow listing on ATM and POS systems.	T1204.002 T1059.001	Critical
DETECT (DE)	DE.CM-01 Network k Monitor	Deploy SSL/TLS inspection at network egress. Implement beaconing detection (JA3/JA3S) and DNS filtering to identify HTTPS C2.	T1071.001 T1102 T1095	Critical
DETECT (DE)	DE.CM-03 User Activity	Monitor for LSASS access (Sysmon EID 10), suspicious SMB Admin Share traversal, and anomalous RDP/WinRM session patterns.	T1003.001 T1021.001 T1021.002	Critical
DETECT (DE)	DE.AE-04 Impact Assess.	Implement UEBA to detect lateral movement patterns and anomalous SWIFT/ACH transaction volumes as early warning indicators.	T1021.002 T1485	High
RESPOND (RS)	RS.MA-01 Incident Mgmt.	Develop and test SWIFT-specific IR playbooks. Establish coordination procedures with FS-ISAC and relevant national CERTs.	T1485 T1041	High
RECOVER (RC)	RC.RP-01 Recovery Plan	Maintain tested offline backups of core banking, SWIFT, and ATM controller systems, isolated from the primary network.	T1485 T1491	High

Table 5: NIST CSF 2.0 Control Mapping (Critical rows = choke-point TTP coverage)

4.2 ISO/IEC 27001:2022 Mapping

Claue	Control Theme	Control Action	TTP Addressed	Priority
5.2	Information Security Policies	Maintain documented policies covering threat intelligence use, APT response, and financial system access controls.	All TTPs	High
5.7	Threat Intelligence	Establish formal CTI programmed sourcing from FS-ISAC, MITRE ATT&CK, and government advisories. Conduct quarterly TTP reviews.	All TTPs	High
8.2	Information Classification	Classify SWIFT credentials, ATM master keys, and interbank routing data as 'Restricted'; enforce strict need-to-know access.	T1003.001 T1552	Critical
8.5	Secure Authentication	Enforce phishing-resistant MFA (FIDO2/hardware tokens) for all privileged and remote access. Implement PAM for admin accounts.	T1078 T1550.001 T1003	Critical
8.7	Protection Against Malware	Deploy EDR with memory protection rules to detect LSASS dumping and Mimikatz-family tools. Block macro execution from internet.	T1003.001 T1204.002 T1059	Critical
8.12	Data Leakage Prevention	Implement DLP to detect and block bulk archive creation and anomalous outbound data flows from payment processing networks.	T1560.001 T1041 T1048	High
8.16	Monitoring Activities	Implement 24/7 SOC monitoring with SIEM use cases targeting beaconing (T1071.001), LSASS access, and lateral movement.	T1071.001 T1003.001 T1021	Critical
8.20	Network Security	Segment SWIFT, ATM, and payment networks. Enforce SMB signing. Deploy SSL/TLS inspection at egress. Block high-risk TLDs.	T1021.002 T1071.001 T1095	Critical
8.22	Web Filtering	Enforce DNS filtering and category-based web proxying to detect and block C2 callbacks and malicious downloads.	T1566.001 T1071.001 T1102	High
8.28	Secure Coding	Apply secure SDLC for in-house financial applications. Perform SCA to detect supply-chain compromise.	T1195.002 T1190	High
8.30	Outsourced Development	Require vendors to demonstrate equivalent security controls. Mandate MFA and code signing for update pipelines.	T1195.002	High

6.3	Security Awareness Training	Deliver quarterly targeted phishing and social engineering training to finance, treasury, and executive staff.	T1566.001 T1204.002	High
-----	-----------------------------	--	---------------------	------

Table 6: ISO/IEC 27001:2022 Control Mapping (Critical rows = choke-point TTP coverage)

4.3 How Controls Reduce Exposure to Overlapping TTPs

The control selection strategy is optimized around the choke-point techniques identified in Task 3. The following explains the causal chain from control to TTP disruption:

LSASS / Credential Access, T1003.001

Enabling Windows Credential Guard (NIST PR.AA-02 / ISO 8.5, 8.7) prevents extraction of NTLM hashes and Kerberos tickets from LSASS memory, directly neutralizing the primary post-compromise capability of both APT38 and APT41. Without harvested credentials, attackers cannot authenticate to SWIFT terminals or financial database servers, effectively halting lateral movement.

Web Protocol C2, T1071.001

SSL/TLS inspection at network egress (NIST DE.CM-01 / ISO 8.16, 8.20) breaks the encryption envelope that HTTPS-based C2 relies on for concealment. Pairing this with JA3/JA3S fingerprinting and DNS-layer filtering degrades the operational effectiveness of APT38, FIN7, and APT41 simultaneously — the highest cross-APT leverage point in the entire control set.

Spear phishing / Macro Execution, T1566.001, T1204.002

Enforcing Office macro block policies for internet-sourced files (NIST PR.PS-04 / ISO 8.7) eliminates the primary initial access mechanism of FIN7 and Silence Group. Email gateway sandboxing and DMARC/DKIM enforcement (ISO 8.22) further reduce successful delivery. Security awareness training (ISO 6.3) provides a human backstop.

SMB Admin Share Traversal, T1021.002

Micro-segmentation of SWIFT terminals, ATM controllers, and payment networks (NIST ID.AM-02, ISO 8.20) prevents SMB-based lateral movement even after a general workstation is compromised. SMB signing enforcement prevents relay attacks used by APT38 and Silence.

Cloud-Based C2 / Exfiltration, T1102, T1567.002

CASB deployment combined with data classification (ISO 8.2, 8.12) allows SOC teams to detect anomalous uploads to cloud storage services, APT29's signature exfiltration channel. DLP policies can block bulk uploads exceeding defined thresholds regardless of destination.

In summary, the controls selected across NIST CSF 2.0 and ISO/IEC 27001:2022 are directly traceable to high-frequency, cross-APT techniques identified through evidence-based threat intelligence. This traceability enables SOC leadership to justify control investment in business-risk terms, priorities remediation based on actual threat actor behavior, and measure detection coverage against the TTPs most likely to be used against the financial services sector.

References & Sources (OSINT)

- MITRE ATT&CK; Enterprise Matrix, <https://attack.mitre.org>
- MITRE ATT&CK; Groups: APT38, FIN7, APT29, APT41, <https://attack.mitre.org/groups/>

- US-CERT Advisory AA21-048A: APT38 SWIFT Attacks
- Mandiant / FireEye: FIN7 Evolution and the Phishing LNK (2017)
- CrowdStrike Adversary Intelligence: APT41 / Double Dragon Profile
- Cybereason: Operation CuckooBees, APT41 Long-Term Persistence (2022)
- Microsoft MSTIC: NOBELIUM / APT29 SolarWinds Campaign (2021)
- Group-IB: Silence, Moving into the Darkside (2019)
- NIST Cybersecurity Framework 2.0, <https://www.nist.gov/cyberframework>
- ISO/IEC 27001:2022 Information Security Management Systems
- IBM X-Force Threat Intelligence Index 2024
- Verizon DBIR 2024, Financial Services Sector Analysis
- FS-ISAC Annual Intelligence Report 2024